AFRICA'SPY

INTELLIGENCE ACADEMY

AFS-C201 · SUPPORT DE COURS ET FICHE DE SYNTHÈSE

Sécurité organisationnelle et contre-mesures défensives

Sécurité du personnel, analyse des menaces et exercices de simulation.

DOMAINE	Contre-espionnage
NIVEAU	Avancé
DURÉE INDICATIVE	18 heures
ÉDITION	13 novembre 2026

Document pédagogique réservé aux apprenants inscrits. Les scénarios, organisations et données cités dans les exercices et études de cas sont fictifs. AFRICA'SPY est un organisme de formation privé ; ce support ne vaut pas diplôme.

Présentation

Ce second volet du module C s'adresse aux responsables sécurité, risk managers et cadres dirigeants. Il relie les dimensions humaine, physique, numérique et organisationnelle de la sécurité dans une démarche cohérente fondée sur l'analyse de risques.

Objectifs pédagogiques	Compétences visées
• Organiser la sécurité des personnels, y compris en déplacement • Conduire une analyse de menaces structurée • Sélectionner des contre-mesures proportionnées • Concevoir et animer un exercice de simulation de crise	• Réaliser une matrice de risques • Rédiger un plan de sécurité des déplacements • Prioriser des contre-mesures selon leur coût et leur efficacité • Animer un exercice sur table

PRÉREQUIS

- Contre-espionnage : menaces et protection de l'information
- Responsabilités managériales ou en sécurité appréciées

SOMMAIRE

01 Sécurité du personnel et des organisations

02 Analyse des menaces

03 Contre-mesures défensives

04 Études de cas et simulations pédagogiques

05 Atelier pratique

CHAPITRE 01

Sécurité du personnel et des organisations

Protéger les personnes, en poste et en mission.

LEÇON Protéger les personnes

Les personnes sont à la fois la première ressource et la première cible. La sécurité du personnel couvre le cycle de vie professionnel et les situations de déplacement.

Le cycle de vie

- **Recrutement** : vérifications proportionnées et légales (diplômes, références), sans enquête intrusive sur la vie privée ;
- **Intégration** : sensibilisation, charte, signature des engagements de confidentialité ;
- **En poste** : formation continue, entretiens réguliers ;
- **Départ** : restitution des équipements, clôture des accès, rappel des obligations.

Sécurité en déplacement

Avant	Pendant	Après
Analyse du pays (avis officiels), itinéraire, contacts d'urgence, équipement informatique dédié	Discrétion, points de contact réguliers, vigilance sur les réseaux Wi-Fi publics	Débriefing, signalement d'incidents, contrôle des appareils

> Le devoir de protection de l'employeur (**duty of care**) impose d'évaluer les risques avant d'envoyer un collaborateur en mission et de prévoir les moyens d'assistance.

LEÇON Approfondissement : la sécurité des voyageurs d'affaires

Les déplacements concentrent des risques informationnels : appareils perdus ou inspectés, réseaux non fiables, conversations entendues.

Check-list numérique

- Emporter un ordinateur et un téléphone dédiés, ne contenant que le nécessaire ;
- Chiffrement intégral activé et mises à jour faites avant le départ ;
- Accès aux ressources de l'organisation via un VPN d'entreprise ;
- Ne pas brancher de clés USB reçues ; recharger sur prise électrique plutôt que sur des ports USB publics ;
- Au retour, faire vérifier les appareils par le service informatique.

Check-list comportementale

- Discrétion dans les lieux publics (taxi, restaurant, salon d'aéroport) ;
- Documents sensibles toujours sous contrôle ;
- Signalement de toute sollicitation inhabituelle.

> **Points clés**
>
> - Moins on emporte de données, moins on en expose.
> - Le retour de mission compte autant que le départ.
> - Respecter les lois du pays visité, y compris lors des contrôles aux frontières.

CHAPITRE 02

Analyse des menaces

Menace, vulnérabilité, impact : la matrice de risques.

LEÇON Conduire une analyse de menaces

Le risque résulte de la combinaison d'une **menace** (un acteur avec une intention et une capacité), d'une **vulnérabilité** (une faiblesse exploitable) et d'un **impact** (la gravité des conséquences).

Évaluer une menace

- **Intention** : l'acteur veut-il nous nuire ? Pourquoi ?
- **Capacité** : en a-t-il les moyens ?
- **Opportunité** : nos vulnérabilités lui offrent-elles une ouverture ?

La matrice probabilité × impact

	Impact faible	Impact modéré	Impact grave
Probable	Moyen	Élevé	**Critique**
Possible	Faible	Moyen	Élevé
Peu probable	Faible	Faible	Moyen

Sources d'information sur les menaces

Rapports publics d'autorités nationales de cybersécurité, bulletins des équipes CERT/CSIRT africaines, alertes sectorielles, retours d'expérience des pairs, incidents internes. L'analyse doit être **actualisée régulièrement** : une matrice figée devient trompeuse.

LEÇON Approfondissement : la méthode du nœud papillon

Le **nœud papillon** (bow-tie) représente un événement redouté au centre, ses **causes** à gauche et ses **conséquences** à droite. Les mesures de prévention s'insèrent entre causes et événement ; les mesures de protection entre événement et conséquences.

```
Causes ──▶ [Prévention] ──▶ ÉVÉNEMENT ──▶ [Protection] ──▶ Conséquences
Hameçonnage   MFA, formation    Compromission    Sauvegardes,      Arrêt d'activité
Mot de passe                    de messagerie    cellule de crise  Fuite de données
```

Cette visualisation, utilisée dans l'industrie et la sûreté, aide les décideurs à voir où investir et à vérifier qu'aucune cause majeure n'est sans barrière.

Points clés

- Prévention à gauche, protection à droite.
- Chaque barrière a un responsable et un test.
- Outil de communication efficace avec la direction.

CHAPITRE 03

Contre-mesures défensives

Prévenir, détecter, réagir, se rétablir.

LEÇON Choisir des contre-mesures

Une contre-mesure réduit la probabilité ou l'impact d'un risque. La défense efficace est **en profondeur** : plusieurs couches complémentaires, de sorte qu'une défaillance isolée ne suffise pas.

Les quatre fonctions

1. **Prévenir** : contrôle d'accès, chiffrement, formation, procédures ;
2. **Détecter** : journalisation, alertes, signalements des personnels ;
3. **Réagir** : plan de réponse, cellule de crise, contacts juridiques et autorités ;
4. **Se rétablir** : sauvegardes testées, plan de continuité, retour d'expérience.

Prioriser

Chaque mesure est évaluée selon son coût, sa facilité de mise en œuvre et sa réduction du risque. Les mesures « à fort effet et faible coût » viennent en premier : double authentification, sauvegardes hors ligne, procédure de contre-appel pour les paiements, sensibilisation.

> **Contre-mesures et droit :** les mesures défensives restent dans le périmètre de l'organisation. « Riposter » contre un attaquant (intrusion en retour, représailles) est illégal et dangereux : on signale aux autorités compétentes.

LEÇON Approfondissement : continuité d'activité et gestion de crise

La **continuité d'activité** organise le maintien des fonctions essentielles lorsqu'un incident survient. La norme ISO 22301 en fournit le cadre de référence.

Deux notions clés

- **RTO** (Recovery Time Objective) : durée maximale d'interruption acceptable ;
- **RPO** (Recovery Point Objective) : perte de données maximale acceptable, exprimée en temps (par exemple 24 h de données).

La cellule de crise

Elle réunit direction, technique, juridique et communication, avec un journal de bord horodaté. Ses premiers réflexes : qualifier l'incident, protéger les personnes et les preuves, informer les autorités et partenaires concernés, communiquer de façon factuelle.

> **Points clés**
>
> - RTO = temps ; RPO = données perdues.
> - Un plan non testé n'est pas un plan.
> - La communication de crise doit être factuelle et coordonnée.

CHAPITRE 04

Études de cas et simulations pédagogiques

S'entraîner par l'exercice sur table.

LEÇON Concevoir un exercice sur table

L'exercice sur table (**tabletop exercise**) réunit les décideurs autour d'un scénario fictif qui se déroule par étapes (« injects »). Il teste les procédures, la coordination et la communication sans aucun risque réel.

Conception en cinq étapes

1. Définir 2 ou 3 objectifs (ex. tester la chaîne d'alerte) ;
2. Écrire un scénario plausible et **entièrement fictif** ;
3. Préparer 5 à 8 injects successifs ;
4. Désigner un animateur et un observateur ;
5. Prévoir un débriefing structuré : ce qui a fonctionné, ce qui doit changer, qui fait quoi et quand.

> Un exercice réussi n'est pas un exercice sans erreurs : c'est un exercice qui révèle les failles avant qu'une vraie crise ne le fasse.

LEÇON Approfondissement : le retour d'expérience (RETEX)

Le **retour d'expérience** transforme un exercice ou un incident en améliorations concrètes.

Trame en quatre questions

1. Qu'était-il prévu ?
2. Que s'est-il réellement passé ?
3. Pourquoi des écarts ?
4. Que changeons-nous, qui en est responsable, pour quelle date ?

Le RETEX est **sans recherche de coupable** (« blameless ») : il analyse les systèmes et les procédures, pas les personnes. Cette approche, issue de l'aéronautique et de la santé, favorise la transparence.

Points clés

- Chaque action corrective a un responsable et une échéance.
- On suit la mise en œuvre lors de l'exercice suivant.
- L'absence de recherche de coupable libère la parole.

CHAPITRE 05

Atelier pratique

Matrice de risques et simulation complète.

EXERCICE PRATIQUE Exercice : matrice de risques

Organisation fictive : une université régionale qui héberge un laboratoire de recherche sur les semences résistantes à la sécheresse.

1. Identifiez six risques (fuite de résultats, rançongiciel, vol de matériel, ingérence via partenariats…).
2. Évaluez chacun : intention, capacité, vulnérabilité, impact.
3. Placez-les dans la matrice.
4. Proposez deux contre-mesures par risque critique, classées par coût.

ÉTUDE DE CAS Étude de cas : exercice « Harmattan »

Simulation pédagogique (fictive). Un groupe logistique découvre un lundi matin que ses serveurs sont chiffrés par un rançongiciel, en pleine période de dédouanement.

- **Inject 1 (08 h 10)** : les agents ne peuvent plus imprimer les déclarations.
- **Inject 2 (09 h 00)** : une demande de rançon apparaît ; les attaquants menacent de publier des données clients.
- **Inject 3 (10 h 30)** : un journaliste appelle le service communication.
- **Inject 4 (12 h 00)** : on découvre que la dernière sauvegarde hors ligne date de trois semaines.

Questions de débriefing

1. Qui aurait dû être alerté, dans quel ordre ?
2. Quelles obligations de notification (autorité de protection des données, clients) s'appliquent ?
3. Pourquoi est-il déconseillé de payer la rançon ?
4. Quelles trois mesures auraient le plus réduit l'impact ?

LEÇON Glossaire de la formation

Les notions essentielles de la formation, à maîtriser pour l'examen final.

Défense en profondeur

Superposition de couches de protection.

Duty of care

Devoir de protection de l'employeur envers ses collaborateurs.

Exercice sur table

Simulation de crise par étapes (injects).

Matrice de risques

Croisement probabilité × impact pour prioriser.

Nœud papillon

Représentation causes – événement – conséquences avec barrières.

RETEX

Retour d'expérience transformé en actions correctives.

RPO

Perte de données maximale acceptable.

RTO

Durée maximale d'interruption acceptable.

LEÇON Pour aller plus loin : bibliographie et ressources

Sélection d'ouvrages, de normes et de ressources reconnues pour prolonger la formation. Les ressources en accès libre sont signalées.

- ISO 22301, Sécurité et résilience — Systèmes de management de la continuité d'activité.
  Référence de la continuité d'activité.
- ISO 31000, Management du risque — Lignes directrices.

Principes généraux de l'analyse de risques.

- ANSSI (France), **Guide d'hygiène informatique** (accès libre).

  Mesures défensives prioritaires et concrètes.

- Union africaine, **Convention sur la cybersécurité et la protection des données à caractère personnel** (Convention de Malabo), 2014, en vigueur depuis 2023.

  Cadre continental de la protection des données.

Ces références sont indiquées à titre pédagogique ; AFRICA'SPY n'a aucun lien d'affiliation avec leurs auteurs ou éditeurs.